

THREAT ADVISORY



**VULNERABILITY
REPORT**

Vulnerability in Fortinet allows authentication bypass

Date of Publication

October 10, 2022

Last updated date

October 11, 2022

Admiralty Code

A1

TA Number

TA2022216

Summary

FortiOS, FortiProxy, and FortiSwitchManager has an authentication bypass vulnerability, CVE-2022-40684, that could allow remote attackers access to the administrative interface and take control of the entire network

CVE Table

CVE	NAME	PATCH
CVE-2022-40684	Authentication bypass vulnerability in administrative interface	

Potential MITRE ATT&CK TTPs

TA0004 Privilege Escalation	TA0005 Defense Evasion	T1548 Abuse Elevation Control Mechanism	T1548.002 Bypass User Account Control
T1068 Exploitation for Privilege Escalation			

Technical Details

#1

The weakness is been identified as CVE-2022-40684, which is a bypass vulnerability that allows an unauthenticated adversary to carry out arbitrary operations on an administrative interface through specially crafted HTTP or HTTPS requests.

#2

As this vulnerability is been exploited-in-the-wild it is highly recommended to upgrade to non-vulnerable versions

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-40684	FortiOS: From 7.0.0 to 7.0.6 and from 7.2.0 to 7.2.1 FortiProxy: From 7.0.0 to 7.0.6 and 7.2.0 FortiSwitchManager: 7.0.0 and 7.2.0	cpe:2.3:o:fortinet:fortios:*.*.*.*.*.*.*,* cpe:2.3:o:fortinet:fortiproxy:*.*.*.*.*.*.*,* cpe:2.3:a:fortinet:fortiswitch_manager:7.2.0:*.*.*.*.*.*.*	CWE-288

Indicator of Compromise (IOC)

TYPE	VALUE
Event Logs	user="Local_Process_Access"

Patch Details

Upgrade to FortiOS version 7.07 or 7.2.2 or above

Upgrade to FortiProxy version 7.07 or 7.2.1 or above

Upgrade to FortiSwitchManager version 7.2.1 or above

Reference

<https://www.rapid7.com/blog/post/2022/10/07/cve-2022-40684-remote-authentication-bypass-vulnerability-in-fortinet-firewalls-web-proxies/>

<https://www.fortiguard.com/psirt/FG-IR-22-377>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

October 10, 2022 • 4:20 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com